

Cyber Threat Intelligence

Executive Briefing

Report Date: June 30, 2026

Generated: 2026-06-30 13:16 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
0	8	8	1	20

2. Executive Summary

As of June 30, 2026, the security operations center has concluded an analysis of 20 identified vulnerabilities, categorized as 0 Critical, 8 High, 8 Medium, and 1 Low. The current organizational risk posture is assessed as High, characterized by significant exposure within software supply chain workflows that necessitate immediate remediation to prevent potential unauthorized code execution. The primary concern is CVE-2026-55698, Lockfile Resolution Hijacking in pnpm, which demands immediate prioritization due to its capacity to facilitate arbitrary byte execution within our development environments. We recommend an aggressive patching posture and the immediate isolation of impacted build pipelines to mitigate the elevated threat level.

3. Critical Action List

- Execute an emergency patch of pnpm to address CVE-2026-55698 within 24 hours to prevent arbitrary byte execution.
- Remediate the arbitrary file write vulnerability in Gonic (CVE-2026-49340) by restricting playlist endpoint access controls within 48 hours.
- Implement configuration hardening for pnpm to mitigate unauthorized native install engine selection (CVE-2026-55697) within 72 hours.
- Apply mandatory manifest identity validation controls to resolve CVE-2026-55487 and prevent lifecycle execution exploits within 72 hours.
- Deploy a filesystem access patch to remediate the path traversal vulnerability in pnpm manifest downloads (CVE-2026-55700) within 96 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
--------	--------------	------	----------	---------	-----

CVE-2026-55698	Lockfile Resolution Hijacking in ...	8.8	High	89/100	CWE-345
CVE-2026-49340	Arbitrary File Write in Gonic Pla...	8.1	High	83/100	CWE-22
CVE-2026-55697	Unauthorized Native Install Engin...	7.5	High	78/100	CWE-78
CVE-2026-55487	Manifest Spoofing Leading to Life...	7.5	High	78/100	CWE-346
CVE-2026-55700	Path Traversal in pnpm Manifest D...	7.1	High	74/100	CWE-22
CVE-2026-49338	IDOR in Subsonic API Playlist Man...	7.1	High	74/100	CWE-285
CVE-2026-49339	Path Traversal in Gonic Playlist ...	7.1	High	74/100	CWE-22
CVE-2026-53523	Host Header Injection in Nezha Mo...	6.8	Medium	71/100	CWE-601
CVE-2026-55699	Unintended Deletion of PNPM_HOME ...	6.5	Medium	69/100	CWE-22
CVE-2026-55180	Environment Secret Exposure via R...	6.5	Medium	69/100	CWE-200
CVE-2026-53522	WebSocket Resource Exhaustion in ...	6.5	Medium	69/100	CWE-770
CVE-2026-44840	DQL Injection in Dgraph GraphQL A...	7.5	High	68/100	CWE-943
CVE-2026-53465	Heap Buffer Overflow in ImageMagi...	6.2	Medium	66/100	CWE-122
CVE-2026-54243	CSV Formula Injection in Statamic...	6.1	Medium	55/100	CWE-1236
CVE-2026-53464	Memory Leak in ImageMagick Wand P...	4.0	Medium	46/100	CWE-401
CVE-2026-54242	SSRF via DNS Rebinding in Statamic	4.9	Medium	44/100	CWE-367
CVE-2026-54244	Authorization Bypass in Statamic ...	3.5	Low	27/100	CWE-863
CVE-2026-48717	OAuth PKCE Authorization Bypass i...	0.0	None	0/100	CWE-285
CVE-2026-47426	OAuth Client Impersonation in Ope...	0.0	None	0/100	CWE-287
CVE-2026-47424	Groovy Sandbox Escape in OpenAM	0.0	None	0/100	CWE-693

5. Detailed Vulnerability Findings

CVE-2026-55698

Finding: Lockfile Resolution Hijacking in pnpm

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 89/100 | CWE: CWE-345

MITRE ATT&CK: T1195, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm allows a project environment lockfile to short-circuit package resolution, enabling the execution of arbitrary bytes defined in the lockfile. This bypasses package integrity checks and can lead to code execution.

Proof of Concept (PoC):

An attacker compromises a project's lockfile, injecting references to malicious package contents. When pnpm performs

an install, it uses these references to download and execute code instead of validated registry packages.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55698>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55698>

CVE-2026-49340

Finding: Arbitrary File Write in Gonic Playlists

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 83/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Gonic allows authenticated users to perform arbitrary file writes through the createPlaylist endpoint by providing malicious M3U playlist content. This can be used to overwrite system files or achieve code execution.

Proof of Concept (PoC):

The user submits a playlist creation request containing file system paths within the M3U content. The backend service writes this content to the specified path, overwriting sensitive files on the server.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49340>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49340>

CVE-2026-55697

Finding: Unauthorized Native Install Engine Selection

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-78

MITRE ATT&CK: T1059, T1195

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm allows repositories to control configDependencies, which can be leveraged to select a paquet native install engine. This can lead to arbitrary code execution during the installation phase.

Proof of Concept (PoC):

A repository configuration defines a malicious native install engine. When pnpm is executed in the repository context, it triggers the selected engine to run unauthorized commands on the host machine.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55697>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55697>

CVE-2026-55487

Finding: Manifest Spoofing Leading to Lifecycle Execution

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-346

MITRE ATT&CK: T1059, T1195

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm is vulnerable to manifest identity spoofing, which satisfies allowBuilds checks and executes arbitrary lifecycle scripts. This allows an attacker to gain control over the build process.

Proof of Concept (PoC):

An attacker provides a spoofed manifest that identifies the package as a trusted dependency. pnpm's build process accepts the identity and executes the attacker-controlled lifecycle scripts.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55487>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55487>

CVE-2026-55700

Finding: Path Traversal in pnpm Manifest Download

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

pnpm's stage download functionality incorrectly handles manifest names, allowing a path traversal vulnerability. An attacker can use crafted package manifests to write files outside the designated installation directory.

Proof of Concept (PoC):

An attacker publishes a malicious package to a registry containing a name attribute with traversal sequences (e.g., ../). When a victim runs pnpm, the package manager writes files to arbitrary locations on the victim's filesystem.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55700>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55700>

CVE-2026-49338

Finding: IDOR in Subsonic API Playlist Management

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-285

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

Subsonic API lacks proper access controls on playlist management endpoints, allowing any authenticated user to view, modify, or delete playlists belonging to other users. This is a classic Insecure Direct Object Reference (IDOR) vulnerability.

Proof of Concept (PoC):

An authenticated user changes the playlist ID in the API request path to a value belonging to another account. The server processes the request and allows the unauthorized modification or access to the target playlist.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49338>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49338>

CVE-2026-49339

Finding: Path Traversal in Gonic Playlist Handling

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

Gonic contains a path traversal vulnerability in its playlist ID parameter, allowing authenticated users to bypass ownership checks. This facilitates unauthorized access to and deletion of arbitrary playlist files on the host system.

Proof of Concept (PoC):

An attacker provides a playlist ID string containing directory traversal characters to the relevant endpoint. The application fails to sanitize the input, allowing the attacker to access files outside the user's restricted directory.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49339>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49339>

CVE-2026-53523

Finding: Host Header Injection in Nezha Monitoring**CVSS v3.1 Score: 6.8 | Severity: Medium | Urgency Score: 71/100 | CWE: CWE-601**

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Nezha Monitoring contains a host header injection vulnerability in its OAuth2 redirect URL. This can be exploited to perform open redirect attacks or redirect users to malicious endpoints.

Proof of Concept (PoC):

An attacker sends a request to the OAuth2 callback with a manipulated Host header. The application generates a redirect URI based on this header, successfully redirecting the user to an external, attacker-controlled domain.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53523>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53523>**CVE-2026-55699****Finding: Unintended Deletion of PNPM_HOME Directory****CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-22**

MITRE ATT&CK: T1485

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	High

Description:

A vulnerability in pnpm's global removal process causes the deletion of the PNPM_HOME directory when a reserved binary name is encountered. This results in the loss of critical application configurations and global tools.

Proof of Concept (PoC):

A local attacker or malicious package triggers a global removal command involving a reserved bin name. pnpm incorrectly identifies the PNPM_HOME directory as target for deletion and recursively removes it.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55699>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55699>**CVE-2026-55180****Finding: Environment Secret Exposure via Registry Requests****CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-200**

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

pnpm's configuration handling allows for the expansion of victim environment secrets into registry requests before scripts run. This leads to the exfiltration of sensitive environment variables to third-party registries.

Proof of Concept (PoC):

An attacker creates a repository with a configuration that references secret environment variables. When a victim runs pnpm in that environment, the secret values are appended to requests sent to the attacker-controlled registry.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55180>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55180>

CVE-2026-53522

Finding: WebSocket Resource Exhaustion in Nezha Monitoring

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-770

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Nezha Monitoring suffers from unbounded WebSocket streams, leading to a resource exhaustion denial-of-service condition. Attackers can open multiple streams to overwhelm server memory or network connections.

Proof of Concept (PoC):

The attacker establishes a large number of concurrent WebSocket connections to the server without closing them. The server exhausts available file descriptors or connection limits, causing a denial of service.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53522>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53522>

CVE-2026-44840

Finding: DQL Injection in Dgraph GraphQL API

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-943

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Dgraph is susceptible to DQL injection via the checkUserPassword GraphQL query endpoint. An attacker can manipulate input parameters to execute unauthorized DQL queries, potentially leading to unauthorized data disclosure or authentication bypass.

Proof of Concept (PoC):

An attacker sends a crafted GraphQL query to the checkUserPassword endpoint containing malicious DQL syntax. The server processes this payload, allowing the attacker to extract sensitive user data or metadata from the Dgraph database.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44840>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44840>

CVE-2026-53465

Finding: Heap Buffer Overflow in ImageMagick

CVSS v3.1 Score: 6.2 | Severity: Medium | Urgency Score: 66/100 | CWE: CWE-122

MITRE ATT&CK: T1203, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	High

Description:

ImageMagick suffers from a heap buffer overflow in the SF3 encoder when processing multi-frame images. This vulnerability could lead to arbitrary code execution when the software processes a malicious image file.

Proof of Concept (PoC):

An attacker provides a specially crafted SF3 image file. Upon processing by an application using ImageMagick, the memory corruption occurs, potentially hijacking control flow.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53465>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53465>

CVE-2026-54243

Finding: CSV Formula Injection in Statamic Exports

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-1236

MITRE ATT&CK: T1566

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

Description:

Statamic is vulnerable to CSV formula injection when exporting form submissions. Maliciously crafted data in submissions can lead to code execution when opened in spreadsheet software by administrators.

Proof of Concept (PoC):

An attacker submits a form entry containing common spreadsheet command injection characters (e.g., '=cmd|'). When a site administrator exports these submissions to CSV and opens them in Excel, the malicious commands execute.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54243>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54243>

CVE-2026-53464**Finding: Memory Leak in ImageMagick Wand Parser**

CVSS v3.1 Score: 4.0 | Severity: Medium | Urgency Score: 46/100 | CWE: CWE-401

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

ImageMagick has a memory leak in the wand option parser when provided with invalid arguments. This could lead to a denial-of-service condition through resource exhaustion.

Proof of Concept (PoC):

An attacker sends a flood of image processing requests with malformed arguments to the service. The service fails to free allocated memory, gradually consuming system resources until crash.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53464>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53464>

CVE-2026-54242**Finding: SSRF via DNS Rebinding in Statamic**

CVSS v3.1 Score: 4.9 | Severity: Medium | Urgency Score: 44/100 | CWE: CWE-367

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None

Attack Complexity	High
User Interaction	None

Scope	Unchanged
Integrity Impact	Low

Confidentiality Impact	Low
Availability Impact	None

Description:

Statamic's Glide image processing component is vulnerable to Server-Side Request Forgery via DNS rebinding. This allows attackers to perform requests to internal network services that would otherwise be blocked.

Proof of Concept (PoC):

An attacker hosts a malicious DNS server and provides a URL pointing to a domain that initially resolves to a safe IP, then quickly resolves to an internal service IP. The Glide component fetches the image, triggering the SSRF during the race window.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54242>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54242>

CVE-2026-54244**Finding: Authorization Bypass in Statamic Live Preview**

CVSS v3.1 Score: 3.5 | Severity: Low | Urgency Score: 27/100 | CWE: CWE-863

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

Statamic CMS allows view-only users to access and submit Live Preview content intended for editors. This authorization flaw permits unauthorized users to interfere with draft content.

Proof of Concept (PoC):

A user with low-level viewing privileges browses to the Live Preview endpoint, which the CMS fails to block. The user then submits updates that modify existing draft content without authorization.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54244>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54244>

CVE-2026-48717**Finding: OAuth PKCE Authorization Bypass in OpenAM**

CVSS v3.1 Score: 0.0 | Severity: None | Urgency Score: 0/100 | CWE: CWE-285

MITRE ATT&CK: T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low

Integrity Impact	Low	Availability Impact	None
------------------	-----	---------------------	------

Description:

OpenAM exhibits an authorization bypass vulnerability within its OAuth implementation related to PKCE challenges. This flaw allows an attacker to intercept or manipulate the authorization flow, potentially gaining unauthorized access tokens.

Proof of Concept (PoC):

An attacker intercepts the authorization code exchange process and provides a mismatched or forged PKCE challenge. If the system fails to strictly validate the challenge mapping, the attacker can hijack the legitimate user's session.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48717>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48717>

CVE-2026-47426

Finding: OAuth Client Impersonation in OpenAM

CVSS v3.1 Score: 0.0 | Severity: None | Urgency Score: 0/100 | CWE: CWE-287

MITRE ATT&CK: T1134

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network	Attack Complexity	High
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	None

Description:

OpenAM fails to correctly manage the JWKS resolver cache, allowing an attacker to manipulate the cache to impersonate legitimate OAuth clients. This enables the attacker to forge access tokens and access protected resources.

Proof of Concept (PoC):

The attacker performs a cache poisoning attack on the JWKS resolver endpoint to inject a malicious public key. Subsequent token validation requests use this key, allowing the attacker to present forged tokens as valid.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-47426>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-47426>

CVE-2026-47424

Finding: Groovy Sandbox Escape in OpenAM

CVSS v3.1 Score: 0.0 | Severity: None | Urgency Score: 0/100 | CWE: CWE-693

MITRE ATT&CK: T1059, T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	High	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	High

Description:

OpenAM allows an authenticated user to perform a Groovy sandbox escape, leading to Remote Code Execution on the host server. This vulnerability stems from improper restrictions on the execution environment within the application.

Proof of Concept (PoC):

An authenticated administrator submits a crafted Groovy script through the administrative configuration interface. The script escapes the sandbox and executes operating system commands under the application service context.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-47424>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-47424>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>